

# Relatório da Atividade Hydra

Este relatório reúne as evidências do laboratório e apresenta a análise solicitada nos tópicos 7, 8 e 9 da atividade. Os testes foram realizados em um ambiente controlado, no endereço 3.235.45.215, utilizando o serviço HTTPS na porta 6901.

## Evidências do laboratório

```
instance_id = "i-09e138ec9e4955043"
kali_desktop_url = "https://3.235.45.215:6901"
public_ip = "3.235.45.215"
ssh_command = "ssh -i <caminho-para-sua-chave>.pem ubuntu@3.235.45.215"
PS C:\Users\ITZ\Desktop\5Semestre\Infra>

root@35f89d2d681d: /home/kasm-user
File Actions Edit View Help
default:~$ sudo su
[sudo] password for kasm-user:
#

root@35f89d2d681d: /home/kasm-user
File Actions Edit View Help
default:~$ sudo su
[sudo] password for kasm-user:
# hydra -v
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-23 22:
25:10
[ERROR] Invalid target definition!
[ERROR] Either you use "www.example.com module [optional-module-parameters]"
*or* you use the "module://www.example.com/optional-module-parameters" syntax
!

#
```

```
(root@35f89d2d681d)-[/home/kasm-user]
# hydra -l kasm_user -p urubu100 -s 6901 -f -vV -t 1 -w 30 3.235.45.215 http-get /
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-23 22:
27:50
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try
per task
[DATA] attacking http-gets://3.235.45.215:6901/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[ATTEMPT] target 3.235.45.215 - login "kasm_user" - pass "urubu100" - 1 of 1
[child 0] (0/0)
[6901][http-get] host: 3.235.45.215 login: kasm_user password: urubu100
[STATUS] attack finished for 3.235.45.215 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-23 22:
27:50
```

```
(root@35f89d2d681d)-[/home/kasm-user]
# hydra -l kasm_user -p urubu1001 -s 6901 -f -vV -t 1 -w 30 3.235.45.215 ht
tps-get /
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-23 22:
32:46
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try
per task
[DATA] attacking http-gets://3.235.45.215:6901/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[ATTEMPT] target 3.235.45.215 - login "kasm_user" - pass "urubu1001" - 1 of 1
[child 0] (0/0)
[STATUS] attack finished for 3.235.45.215 (waiting for children to complete t
ests)
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-23 22:
32:46
```

# Respostas da atividade

## 7 Análise do resultado

### O ataque teve sucesso ou falha

O primeiro teste teve sucesso. O Hydra encontrou uma combinação válida de credenciais e apresentou a mensagem "valid pair found". O segundo teste, realizado com uma senha incorreta, falhou e terminou com "0 valid password found".

### Quanto tempo levou o teste

Nos dois testes, os horários de início e término aparecem dentro do mesmo segundo. O teste com a senha correta começou e terminou às 22:27:50, enquanto o teste com a senha incorreta começou e terminou às 22:32:46. Portanto, cada execução levou menos de um segundo, considerando a precisão exibida pelo Hydra.

### Qual foi a quantidade de alvos e senhas testados

Em cada execução foi testado um alvo, um usuário e uma senha, totalizando uma tentativa de autenticação por execução.

### Qual foi a porta utilizada

Foi utilizada a porta 6901.

### Qual usuário e senha foram confirmados

O Hydra confirmou o usuário kasm\_user e a senha urubu100. O teste foi realizado contra o endereço IP público 3.235.45.215.

### O que o resultado demonstra sobre a segurança do mecanismo de autenticação

O resultado demonstra que o mecanismo distingue uma senha válida de uma senha inválida. Também mostra que uma credencial correta pode ser testada e confirmada automaticamente pelo Hydra. Se o serviço permitir muitas tentativas sem limitação, utilizar senhas fracas ou não exigir um segundo fator, ele poderá ficar exposto a ataques de força bruta ou de dicionário. Como as evidências mostram somente uma tentativa por execução, este teste não permite afirmar que o serviço esteja sem bloqueio ou limitação de tentativas.

## 8 Comparação dos resultados

### Senha correta

Quando a senha correta urubu100 foi utilizada, o serviço aceitou a autenticação. O Hydra exibiu o endereço do alvo, a porta, o usuário, a senha e a informação de que uma senha válida foi encontrada.

### Senha incorreta

Quando a senha urubu1001 foi utilizada, o Hydra completou a tentativa, mas não encontrou nenhuma credencial válida. O resultado apresentado foi "0 valid password found", indicando que o serviço rejeitou a senha incorreta.

## Protocolos SSH HTTP e FTP

As evidências fornecidas mostram apenas a execução do módulo HTTPS GET. Assim, os comportamentos a seguir representam o resultado esperado para os demais protocolos.

| Protocolo | Comportamento esperado                                                        | Avaliação no ambiente                                                                                                                                                  |
|-----------|-------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| SSH       | O Hydra procura um serviço SSH e tenta realizar a negociação desse protocolo. | Na porta 6901, que oferece HTTPS, a negociação SSH não deve ser concluída. Na porta 22, o teste só funciona se houver um serviço SSH ativo e acessível.                |
| HTTP      | O módulo HTTP sem criptografia espera respostas HTTP normais.                 | Como a porta 6901 utiliza HTTPS, o uso de HTTP simples pode causar erro, redirecionamento, resposta inválida ou encerramento da conexão por incompatibilidade com TLS. |
| FTP       | O módulo FTP espera o banner e as respostas de um servidor FTP.               | A autenticação não deve prosseguir na porta 6901. O teste só faz sentido em uma porta que realmente ofereça FTP, normalmente a porta 21.                               |

## Protocolo diferente do serviço disponível

Quando o protocolo selecionado não corresponde ao serviço disponível na porta, o Hydra não consegue realizar corretamente a comunicação. Podem ocorrer erros de conexão, falhas de negociação, timeouts ou nenhuma credencial válida encontrada. Esse resultado não significa necessariamente que o usuário ou a senha estejam errados; ele pode indicar apenas que o módulo, o protocolo ou a porta foram configurados incorretamente. Por isso, o serviço disponível deve ser identificado antes do teste.

## 9 Relação com Segurança da Informação

Os controles abaixo dificultam ou impedem ataques automatizados de autenticação.

- Adotar senhas longas, únicas e resistentes a ataques de dicionário.
- Impedir o uso de senhas comuns, previsíveis ou já comprometidas.
- Aplicar bloqueio temporário ou atrasos progressivos depois de várias falhas.
- Utilizar rate limiting por usuário, endereço IP e intervalo de tempo.
- Exigir autenticação multifator.
- Registrar tentativas bem-sucedidas e malsucedidas em logs.
- Criar alertas para falhas repetidas, acessos incomuns ou autenticações de origens desconhecidas.
- Restringir a porta 6901 por Security Group, firewall, VPN ou lista de endereços IP autorizados.
- Desabilitar serviços e portas que não sejam necessários.
- Utilizar IDS, IPS, WAF ou Fail2ban para detectar e bloquear comportamentos suspeitos.
- Evitar registrar ou armazenar senhas em texto puro nos logs e relatórios.

# Três perguntas do ecossistema da Auditoria Sistemática

## Quem pode fazer o quê

O usuário kasm\_user pode realizar a autenticação no serviço HTTPS disponível em 3.235.45.215:6901 quando apresenta a senha correta. O acesso deve ser controlado por regras de rede, princípio do menor privilégio, autenticação multifator e permissões limitadas às funções necessárias.

## Quem fez o quê e quando

As evidências permitem identificar o alvo, a porta, o usuário, o resultado e o horário dos testes. Às 22:27:50 ocorreu uma autenticação bem-sucedida e, às 22:32:46, uma tentativa com senha incorreta foi rejeitada. Em um ambiente real, os logs também devem registrar o IP de origem, o identificador do usuário, o serviço acessado e o resultado. A senha não deve ser armazenada em texto puro.

## O que está acontecendo no ambiente

O ambiente recebeu duas tentativas automatizadas de autenticação: uma bem-sucedida e outra malsucedida. Um sistema de monitoramento deve detectar o aumento de tentativas, gerar alertas e permitir uma resposta rápida, como bloqueio temporário, limitação de requisições ou isolamento da origem suspeita. O experimento mostra a importância de combinar controlabilidade, auditabilidade e visibilidade: controlar quem pode acessar, registrar as ações realizadas e detectar comportamentos suspeitos enquanto eles acontecem.